DBMS 계정 관리 보안 점검 가이드

Oracle DB, MSSQL, MySQL, Altibase, Tibero, PostgreSQL 등 주요 DBMS의 계정 관리 보안 항목(D-05 ~ D-08)에 대한 점검 방법과 조치 사례를 정리한 실무 가이드입니다.

1

D-05

비밀번호 재사용 제약 설정

2

D-06

개별 계정 부여

3

D-07

root 권한 서비스 구동 제한

4

D-08

안전한 암호화 알고리즘 사용

D-05 · 중요도: 중

비밀번호 재사용 제약 설정

점검 목적

비밀번호 변경 시 이전 비밀번호 재사용을 원천 차단하여 형식적인 비밀번호 변경을 방지합니다.

보안 위협

재사용 제약이 없으면 비인가자의 비밀번호 추측 공격에 노출되는 시간이 늘어나 유출 위험이 증가합니다.

판단 기준

✅ 양호

비밀번호 재사용 제한 설정 적용

❌ 취약

비밀번호 재사용 제한 설정 미적용

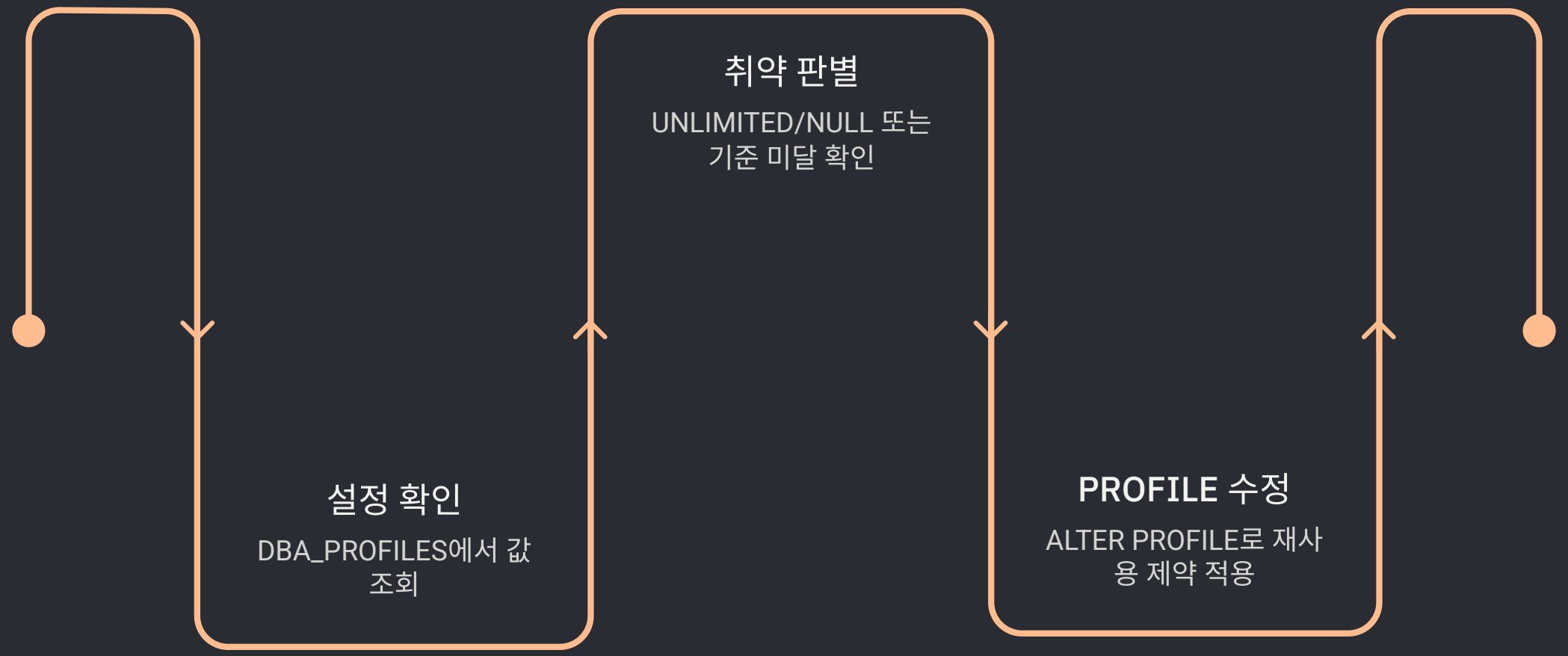
핵심 파라미터

- **PASSWORD_REUSE_TIME**: 이전 암호 재사용 가능 기간
- **PASSWORD_REUSE_MAX**: 이전 암호 재사용 가능 횟수

대상: Oracle DB, Altibase, Tibero 등

D-05 · ORACLE DB 조치

Oracle DB — 비밀번호 재사용 제약 설정



Oracle DB는 **DBA_PROFILES** 뷰를 통해 현재 설정을 확인하고, `ALTER PROFILE default LIMIT password_reuse_time 365 password_reuse_max 10;` 명령으로 조치합니다. 권장 기준은 **REUSE_TIME ≥ 365일, REUSE_MAX ≥ 10회**입니다.

D-05 · ALTIBASE / TIBERO 조치

Altibase & Tibero — 비밀번호 재사용 제약 설정

Altibase

`SELECT * FROM system_sys_users;` 로 정책 확인 후, `ALTER USER [계정명] LIMIT (PASSWORD_REUSE_TIME 365, PASSWORD_REUSE_MAX 10);` 으로 적용합니다.

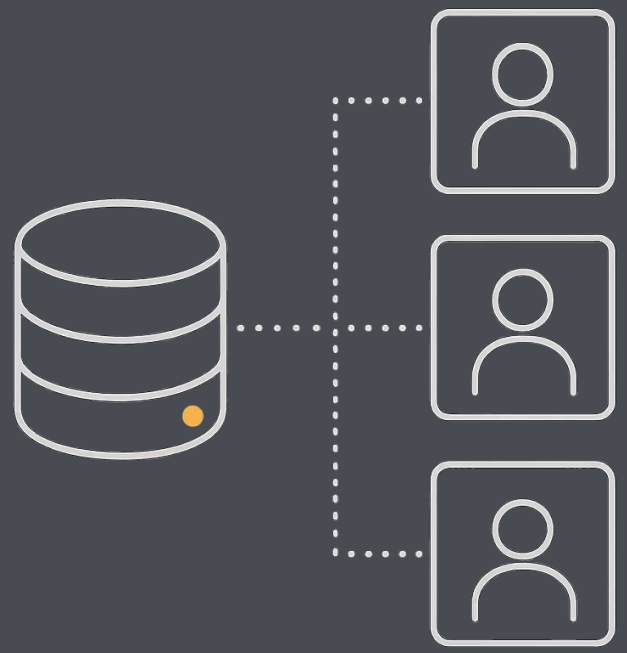
추가 설정 항목: `FAILED_LOGIN_ATTEMPTS`, `PASSWORD_LOCK_TIME`, `PASSWORD_LIFE_TIME` 등

Tibero

`SELECT * FROM dba_users;` 로 PROFILE 적용 여부 확인 후, PROFILE이 없으면 `CREATE PROFILE`로 신규 생성합니다.

```
CREATE PROFILE profLIMIT
  password_reuse_time unlimited
  password_reuse_max 10
  password_grace_time 10
  password_verify_function verify_function;
```

조치 시 영향: 일반적인 경우 서비스 영향 없음



D-06 · 중요도: 중

DB 사용자 계정 개별 부여

점검 내용

DB 접근 시 사용자별로 서로 다른 계정을 사용하는지 점검합니다.

보안 위험

공용 계정 사용 시 비인가자 접근 발생 시 로그 감사 추적이 어려워집니다.

판단 기준

양호: 사용자별 계정 사용
취약: 공용 계정 사용

대상 DBMS

Oracle DB, MSSQL, MySQL, Altibase, Tibero, PostgreSQL 등

D-06 · 조치 사례

개별 계정 부여 — DBMS별 조치 방법

Oracle DB

공용 계정 삭제 후 개별 계정 생성 및 권한 부여

```
DROP USER '공용계정';
CREATE USER '계정명' IDENTIFIED BY '비밀번호';
GRANT connect, resource TO [계정명];
```

MSSQL

공용 계정 삭제 후 LOGIN/USER 생성

```
EXEC sp_droplogin '공용계정';
CREATE LOGIN '계정' WITH PASSWORD='비밀번호';
CREATE USER '계정' FOR LOGIN '계정';
```

MySQL

공용 계정 삭제 후 최소 권한 원칙으로 계정 생성

```
DROP USER 계정@'호스트';
CREATE USER '계정'@'호스트' IDENTIFIED BY '비밀번호';
GRANT select, insert ON DB명.테이블명 TO '계정'@'호스트';
```

Altibase / Tibero / PostgreSQL

공용 계정 CASCADE 삭제 후 목적별 계정 생성

```
DROP USER 계정 CASCADE;
CREATE USER 계정 IDENTIFIED BY 비밀번호;
-- PostgreSQL: ALTER ROLE 계정 권한명;
```

⚠ MySQL에서 모든 권한(ALL PRIVILEGES) 부여는 편리하나, 보안상 필요한 최소 권한만 부여해야 합니다.

D-07 · 중요도: 중

root 권한으로 서비스 구동 제한

점검 목적

root 권한을 제한적으로 사용하여 시스템 손상, 데이터 유출·변조, 감사 추적 어려움 등의 보안 위협을 방지합니다.

판단 기준

- **양호**: 별도 전용 계정으로 DBMS 구동
- **취약**: root 계정 또는 root 권한으로 구동

대상: Oracle DB, MySQL, Altibase, Cubrid 등

DBMS별 확인 명령어

DBMS	프로세스 확인 명령어
Oracle DB	`ps -ef | grep pmon`
MySQL	`ps -ef | grep mysqld`
Altibase	`ps -ef | grep altibase`
Cubrid	`ps -ef | egrep 'cub_master|cub_broker'`

ⓘ MySQL은 `/etc/my.cnf`의 `[mysqld]` 섹션에서 `user=mysql` 설정 여부를 추가 확인합니다.

D-07 · 조치 사례

root 권한 제한 — DBMS별 조치 절차

01

Oracle DB

oracle 전용 계정으로 전환 → `lsnrctl stop` → `shutdown immediate` → `lsnrctl start` → `startup` 순서로 서비스 재시작

02

MySQL

설정 파일(/etc/my.cnf.d/mysql-server.cnf)의 `[mysqld]` 그룹에 `user = mysql` 지시자를 설정하여 일반 계정으로 구동

03

Altibase

`chown -R [계정명]:[그룹명] '[Altibase 디렉터리]'` 로 소유자 변경 후 Altibase 전용 계정으로 DB 재구동

04

Cubrid

cubrid 전용 계정으로 재설치하거나, 동일 DB 생성 후 언로드/로드 방식으로 기존 데이터 이관

D-08 · 중요도: 상

안전한 암호화 알고리즘 사용

점검 목적 및 위협

SHA-256 이상의 해시 알고리즘 사용으로 데이터 기밀성·무결성을 보장하고 사용자 인증을 강화합니다.

SHA-1, MD5 등 구형 알고리즘 사용 시 무차별 대입 공격으로 비밀번호 유추 및 데이터 변조·유출 위험이 존재합니다.

Oracle DB 버전별 알고리즘

10G

MD5 (취약)

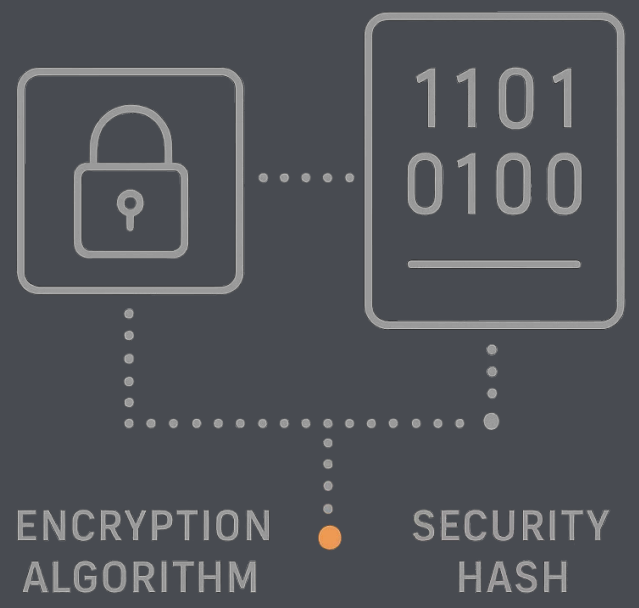
11G

SHA-1 (취약)

12C

SHA-512, AES (양호)

MSSQL 2012 이상: 32bit Salt 적용 SHA-512 해시 알고리즘 사용 (양호)



D-08 · 조치 사례

암호화 알고리즘 조치 — Oracle & MSSQL

Oracle DB 조치

Step 1) 암호화 버전 확인

```
SELECT username, password_versions FROM dba_users;
```

Step 2) sqlnet.ora 파일 수정으로 SHA-512 기반 12C 인증 강제 적용

```
SQLNET.ALLOWED_LOGON_VERSION_SERVER = 12
SQLNET.ALLOWED_LOGON_VERSION_CLIENT = 12
```

MSSQL 일반 이용자 패스워드 해시 변경

Step 1) 기존 해시 확인: `SELECT name, password_hash FROM sys.sql_logins;`

Step 2) 신규 SHA2_256 컬럼 추가 → 암호화 데이터 저장 → 기존 컬럼 삭제

```
ALTER TABLE 테이블명 ADD 신규컬럼 varbinary(256);
UPDATE 테이블명 SET 신규컬럼 = HASHBYTES('SHA2_256', 기존컬럼);
ALTER TABLE 테이블명 DROP COLUMN 기존컬럼;
```

조치 시 영향: 일반적인 경우 서비스 영향 없음. 판단 기준 — 양호: SHA-256 이상 사용 / 취약: SHA-256 미만 사용